PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Architecture sécurisée de SI

03-180 ANSSI - Architecture sécurisée de SI — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'analyse de risque, comme EBIOS Risk Manager, doit être menée préalablement à la conception d'une architecture.
2. La défense en profondeur repose sur l'application de barrières complémentaires, indépendantes, maîtrisées et surveillées.
3. Le cloisonnement des ressources doit s'effectuer en fonction des risques et des besoins métier.

Principes d'architecture sécurisée

Notion	À retenir
Analyse et cloisonnement	Réaliser une **analyse de risque** (ex: **EBIOS Risk Manager**) et connaître le **contexte réglementaire**. Cloisonner selon les **risques**, les **besoins métier**, l'**exposition** et la **sensibilité des données**.
Défense et flux	Appliquer la **défense en profondeur** via des barrières **complémentaires**, **indépendantes**, **maîtrisées** et **surveillées**. Les flux circulent de la **haute confiance** vers la **moindre confiance** (ex : SI d'administration → bureautique, jamais l'inverse).
Privilèges et documentation	Sécuriser les **privilèges élevés** (administration) en les **cloisonnant de la production**. Maintenir une **cartographie** et des **inventaires** à jour. Motiver les choix par des **besoins métier avérés**.

Thématiques du dossier d'architecture technique

Notion	À retenir
Contexte et accès	Couvrir les contextes **métier** et **réglementaire**, la **sensibilité des données**, l'**identification**, l'**authentification** et la **gestion des droits**.
Administration et cloisonnement	Traiter l'**administration** (**comptes à privilèges**, **DevSecOps**), le **cloisonnement** (réseau, système, stockage), le **chiffrement** et le **filtrage des flux**.
Maintien et accès externes	Couvrir le **MCS** (**maintien en condition de sécurité**), les **accès à distance** (**nomadisme**, **accès tiers**) et les **interconnexions** (dont **Internet**).
Protection et supervision	Traiter la **protection codes malveillants**, la **sécurité physique** (accès, vidéoprotection), la **continuité/reprise** (**sauvegardes**) et la **supervision** (**journalisation**, **détection**, **traitement incidents**).

Thématiques approfondies par les publications de l'ANSSI

- **Administration sécurisée** : systèmes d'information en contexte Microsoft Active Directory.
- **Choix de pare-feux** : dans les zones exposées à Internet.
- **Architectures DNS** : architectures des services DNS.
- **Protection des SI essentiels** : protection des systèmes d'information essentiels.
- **Modèle Zero Trust** : le modèle Zero Trust.
- **Hébergement Cloud** : hébergement dans le cloud des systèmes d'information sensibles.
- **Architectures SI sensibles ou de diffusion restreinte** : architectures de systèmes d'information sensibles ou de diffusion restreinte.
- **Interconnexions multiniveaux** : architectures des interconnexions multiniveaux.

Pièges et confusions

- ⚠ Faire circuler les flux de la zone de moindre confiance vers la zone de plus haute confiance.
- ⚠ Complexifier inutilement un système d'information sans lien avec un usage réel.
- ⚠ Oublier de motiver les choix d'architecture par des besoins métier avérés.
- ⚠ Négliger la séparation des privilèges élevés de la production.

Sigles et définitions

Architecture sécurisée de SI	Ensemble des choix de conception et d'évolution d'un SI ayant des conséquences directes sur son niveau de sécurité.
EBIOS Risk Manager	Méthode d'analyse de risque que l'ANSSI recommande de mener préalablement à la conception d'une architecture.
Cloisonnement	Séparation des ressources d'un système d'information en fonction des risques et des besoins métier.
Dossier d'architecture technique	Document qui rassemble et documente les choix de conception d'un système d'information selon un ensemble de thématiques attendues.
MCS	Maintien en condition de sécurité.

Auto-test

1. Quelle méthode d'analyse de risque l'ANSSI recommande-t-elle ?
2. Dans quel sens les flux doivent-ils circuler ?
3. Quels types de ressources peut-on cloisonner ?
4. Que doit-on éviter en complexifiant un SI uniquement pour la sécurité ?
5. Quels sont les quatre critères des barrières de la défense en profondeur ?

Réponses : **1.** EBIOS Risk Manager · **2.** De la zone de plus haute confiance vers la zone de moindre confiance · **3.** Réseau, système et stockage · **4.** La complexification inutile sans lien avec un usage réel · **5.** Complémentaires, indépendantes, maîtrisées et surveillées

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.